



Assets, Threats, Vulnerabilities

Module 1

Risk: Anything that can impact the confidentiality, integrity, or availability of an asset.

Assets: an item perceived as having value to an org

Threats: Any circumstance or event that can negatively impact assets.

Vulnerabilities: A weakness that can be exploited by a threat

Asset management: the process of tracking assets and the risks that affect them

Asset Inventory: A catalog of assets that need to be protected

Asset Classification: the practice of labeling assets based on sensitivity and importance to an org

- Public

- Internal-only - In company

- Confidential - For projects only

- Restricted - High level clearance, need to know

Data: information that is translated, processed, or stored by a computer

Data in use: Data being accessed by one or more users

Data in transit: data traveling from one point to another

Data not currently being accessed

Information security (InfoSec): The practice of keeping data in all states away from unauthorized users.

Elements of a security plan

Policies: A set of rules that reduces risk and protects information

Standards: References that inform how to set policies

Procedures: Step by step instructions to perform a specific security task

Compliance: the process of adhering to internal standards and external regulations

Regulations: rules set by government or other authority to control the way something is done

NIST Cybersecurity Framework (CSF): A Voluntary framework that consists of standards, guidelines, and best practices to manage cybersecurity risk.

Core

Identify

Protect

Detect

Repond

Recover

Tiers

Range from Tier 1 to Tier 4

Tier 1 or passive: indicates a function is reaching bare minimum standards.

Tier 4 or adaptive: indication that a function is being performed at an ememplary standard

Profiles

Pre-made templates of the NIST CSF.

Module 2

Security controls: safeguards designed to reduce specific security risks

Types of security controls:

Technical

Operational

Managerial

Information Privacy: The protection of unauthorized access and distribution of data

Principle of least privilege: the concept of granting only the minimal access and authorization required to complete a task or function

Data owner: the person that decides who can access, edit, use, or destroy their information

Data custodian: Anyone or anything that's responsible for the safe handling, transport, and storage of information.

Data steward: the person or group that maintains and implements data governance policies set by an org

Data life cycle:

Collect

Store

Use

Archive

Destroy

Information security (InfoSec): refers to the practice of keeping data in all states away from unauthorized users.

Information privacy: refers to the protection from unauthorized access and distribution of data.

Personally identifiable information (PII): Any information that can be used to infer an individual's identity.

Cryptography: the process of transforming information into a form that unintended readers can't understand.

Algorithm: A set of rules used that solve a problem

Cipher: An algorithm that encrypts information

Cryptographic key: a mechanism that decrypts ciphertext

Brute force attack: A trial and error process of discovering private information

Public Key Infrastructure (PKI): An encryption framework that secures the exchange of information online.

Process

1. Exchange of encrypted information
2. Establish trust using a system of digital certificates

Asymmetric encryption: The use of public and private key pair for encryption and decryption of data.

RSA

DSA

Symmetric encryption: The use of a single secret key to exchange information

Triple DES

AES

Digital certificate: A file that verifies the identity of a public key holder.

Hash function: An algorithm that produces a code that can't be decrypted.

Non-repudiation: The concept that the authenticity of information can't be denied.

Access controls: Security controls that manage access, authorization, and accountability of information.

AAA framework

Authentication: Access control, ask anything attempting to access information: who are you?

1. Knowledge: something the user knows
2. Ownership: something the user possesses

3. Characteristic: something the user is

Authorization: What someone is allowed to do? Access to information only last as long as needed.

Separation of duties: The principle that users should not be given levels of authorization that would allow them to misuse a system.

Accounting: practice of monitoring the access logs of a system

Single sign-on (SSO): A technology that combines several different logins into one

Multi-factor authentication (MFA): A security measure which requires a user to verify their identity in two or more ways to access a system or network.

Basic Auth: The technology used to establish a user's request to access a server

OAuth: An open- standard authorization protocol that shares designated access between applications

API token to authenticate users.

API Token: A small block of encrypted code that contains information about a user.

Session: A sequence of network HTTP basic auth requests and responses associated with the same user.

Session ID: A unique token that identifies a user and their device while accessing the system.

Session cookie: A token that websites use to validate a session and determine how long that session should last.

Session hijacking: An event when attackers obtain a legitimate user's session ID.

Granting auth

Mandatory access control (MAC): need to know basis

Discretionary access control (DAC): applied when a data owner decides appropriate level of access.

Role-based access control (RBAC): when authorization is determined by a users role within an org.

Module 3

Vulnerability: A weakness that can be exploited by a threat

Exploit: A way of taking advantage of a vulnerability

Vulnerability management: The process of finding and patching vulnerabilities

1. Identify vulnerabilities
2. Consider potential exploits
3. Prepare defenses against threats
4. Evaluate those defenses

Zero-day: an exploit that was previously unknown

CI/CD automates the entire software release process, from code creation to deployment

Continuous Integration (CI): Build a solid foundation

Build → Test → Merge

Continuous Delivery (CD): Ready to release

Automatically release to repo

Continuous Deployment(CD): Fully automated releases

Automatically deploy to production

CI/CD pipelines is non-negotiable

Secure automation

Improved code quality via security checks

Faster time to market for security updates

Enhanced collaboration and feedback with safety focus

reduced risks

Defense in depth: A layered approach to vulnerability management that reduces risk

1. Perimeter layer: user auth layer
2. Network layer: Authorizarion, network firewalls
3. End point layer: Devices that have access on a network, anti virus software
4. Application Layer: security measures are programmed as part of an application like MFA.
5. Data Layer: PII must be protected

Exposure: A mistake that can be exploited by a threat

Common vulnerabilities and exposures list (CVE LIST): An openly accessible dictionary of known vulnerabilities and exposures.

Created by MITRE: A collection of non-profit research and development centers.

CVE numbering authority (CNA): An org that volunteers to analyze and distribute information on eligible CVEs

CVE list criteria

1. Independent of other issues
2. Recognized as a potential security risk
3. Submitted with supporting evidence
4. Only affect one codebase

Common vulnerability scoring system (CVSS): A measurement system that scores the severity of a vulnerability.

OWASP top 10

Broken access control: Access controls limit what users can do in a web application

Cryptographic failures: Encrypt things like PII and SPIIs.

Injection: Malicious code is inserted into a vulnerable application

Insecure design: applications should be designed in a way that makes them resilient to attacks.

Security misconfiguration: When settings aren't properly configured or maintained.

Vulnerable and outdated components: Using open source libraries that are vulnerable or outdated.

Identification and authentication failures: When applications fail to recognize who should have access and what they are authorized to do.

Software and data integrity failures: Updates and patches are not reviewed before implementation.

Security logging and monitoring failure: Always have a record of events like user login.

Server-side request forgery(SSRFs):

Vulnerability assessment: The internal review process of an orgs security systems

Assesment process:

1. Identification: Current state of a system
2. Vulnerability analysis: Vulnerabilities that were found are tested
3. Risk assessment: A score is assigned based on two factors:
 - a. How severe the impact would be if the vulnerability were to be exploited and the likelihood of this happening.
4. Remediation: Depending on the severity score assigned during the risk assessment step.

Vulnerability scanner: Software that automatically compares known vulnerabilities and exposures against the technologies on the network.

Attack surface: All the potential vulnerabilities that a threat actor could exploit.

Security Hardening: the process of strengthening a system to reduce its vulnerabilities and attack surface

Attacker vectors: the pathways attackers use to penetrate security defenses.

Practicing an attacker's mindset:

1. Identify a target
2. Determine how the target can be accessed
3. Evaluate attack vectors that can be exploited
4. Find the tools and methods of attack

Defending attack vectors:

1. Educating users
2. Applying the principle of least privilege
3. Using the right security controls and tools
4. Building a diverse security team

Module 4

Social engineering: A manipulation technique that exploits human error to gain private info, access, or valuables

1. Prepare
2. Establish trust
3. Use persuasion tactics
4. Disconnect from the target

Prevent social engineering

1. Implement managerial controls
2. staying informed of trends
3. sharing your knowledge with others

Phishing: the use of digital communications to trick people into revealing sensitive data or deploying malicious software.

Phishing kit: A collection of software tools needed to launch a phishing campaign

Phishing kit tools

Malicious attachments

Fake data-collection forms

Fraudulent weblinks

Smishing: the use of text messages to obtain sensitive information or to impersonate a known source

Phishing security measures:

Anti-phishing policies

Employee training resources

Email filters

Intrusion prevention systems

Malware: software designed to harm devices or networks

Virus: Malicious code

Worm: malware that can duplicate and spread itself across systems on its own.

Trojan: malware that looks like a legitimate file or program.

Adware: Advertising supported software, potentially unwanted application (PUA) ads/popup designed to bombard pc.

Spyware: Malware that used to gather and sell information without consent.
Considered PUA

Scareware: PUA, malware employs tactics to frighten users into infecting their own device.

Fileless malware: doesn't need to be installed by the user because it uses legitimate programs that are already installed to infect a computer.

- Resides entirely in volatile memory (RAM)

Rootkits: malware that provides remote, administrative access to a computer.

- Spread by a combination of two components

 - Dropper: malware comes packed with malicious code which is delivered and installed onto a target system.

 - Loader: malware that downloads strains of malicious code from an external source and installs them onto a target system.

Botnet: "Robot network", a collection of computers infected by malware that are under control of a single threat actor, known as the bot-herder.

Ransomware: malicious attack where threat actors encrypt an organization's data and demand payment to restore access.

Cryptojacking: A form of malware that installs software to illegally mine cryptocurrencies

- Slowdown

- Increased CPU usage

- Sudden system crashes

- Fast draining batteries

- Unusually high electricity costs

Intrusion detection systems(IDS): An application that monitors system activity and alerts on possible intrusions.

Web-based exploits: Malicious code or behavior that's used to take advantage of coding flaws in web application.

Injection attack: malicious code inserted into a vulnerable application.

- Works normally

runs in the background

Cross-site scripting(XSS): An injection attack that inserts code into vulnerable website or web application.

HTML AND JAVASCRIPT

Types of XSS attack

Reflected: An instance when malicious script is sent to a server and activated during the servers response

Stored: An instance when malicious script is injected directly on the server

Document object model, DOM-based: An instance where malicious script exists in the webpage a browser loads

Structured Query Language (SQL): A programming language used to create, interact with, and request information from a database.

SQL injection: an attack that executes unexpected queries on a database

Categories

In-band: uses same communication channel to launch the attack and gather results.

Ex: Inject in text box and results in the text box

Out-of-band: different communication channel to launch attack and gather results.

Ex: malicious query to create a connection between a vulnerable website and a database they control.

Inferential: Unable to directly see the results of their attack, instead they can interpret the results by analyzing the behavior of the system.

Ways to escape user inputs:

Prepared statement: a coding technique that executes SQL statements before passing them on to database.

Input sanitization: programming that removes user input which could be interpreted as code.

Input validation: programming that ensures user input meets systems expectations.

Threat modeling: The process of identifying assets, their vulnerabilities, and how each is exposed to threats.

6 Steps

1. Define the scope: Inventory of assets
2. Identify threats: define threat actors
 - a. Attack tree: A diagram that maps threats to assets
3. Characterize the environment: Attacker mindset
4. Analyze threats: Examine existing protection and indentify gaps
 - a. Rank threats according to their risk score
5. Mitigate risks: How to defend against threats
 - a. Avoid risks
 - b. Transfer risks
 - c. reduce risks
 - d. accept risks
6. Evaluate findings: Document everything, fixes are applied and

PASTA: A popular threat modeling framework that's used across many industries.

Process for Attack Simulation and Threat Aalysis

7 Stages

1. Define business and security objectives
2. Define the technical scope
3. Decompose the application
4. Perform a threat analysis
5. Perform a vulnerability analysis
6. Conduct attack modeling
7. Analyze risk and impact